

PROMPT IA 15

Security + Privacy + Compliance Engineering

Zero Trust - GDPR - Data Minimization - IAM - Secrets - KMS - Supply Chain - Audit - Retention

Mission : transformer les decisions de securite et privacy du projet e-commerce en controles techniques, politiques-as-code, workflows automatises, preuves auditables et gates CI/CD.

security-by-design - privacy-by-design - least privilege - evidence-based compliance

1. Role de l'IA

Tu es Principal Security Engineer / Privacy Engineer. Implemente les controles sans casser les contrats metier ni introduire de dependances SaaS inutiles. Toute protection critique doit etre testable, observable, versionnee et documentee.

Ne presente jamais ce livrable comme une certification juridique automatique. L'implementation fournit des controles et des preuves techniques ; les obligations legales finales doivent rester validables par les responsables juridiques/compliance.

2. Principes non negociables

- Backend authoritative pour toute decision sensible.
- Least privilege pour humains, workloads, CI et integrations externes.
- Default deny reseau et egress.
- Aucun PAN complet ni CVV stocke.
- Aucun secret longue duree dans Git ou ConfigMap.
- PII minimale : chaque champ doit avoir une finalite documentee.
- Chiffrement en transit et au repos.
- Audit des actions privilegiees et financieres.
- Separation des responsabilites et approbation renforcee Tier 0.
- Tout changement durable passe par GitOps/IaC lorsque raisonnablement possible.

3. Threat modeling

Produire un threat model par domaine critique : IAM, Checkout/Payment, Admin, Webhooks, Supply Chain, Kubernetes, Data Platform et multi-site.

Asset -> Trust boundary -> Threat -> Existing control
-> Residual risk -> Mitigation -> Test -> Evidence -> Owner

Utiliser STRIDE comme grille si utile, sans transformer le processus en documentation decorative. Chaque risque important doit mener a un controle ou a une acceptation explicite.

4. Classification des donnees

Classe	Exemples	Regle
Public	catalogue public	Diffusable.
Internal	runbooks, metadata	Acces interne controle.
Confidential	email, telephone, adresse livraison	Minimisation + RBAC + retention.
Restricted	secrets, credentials, tokens sensibles	OpenBao/HSM, acces strict, audit.
Payment sensitive	PAN/CVV	Ne jamais stocker sur la plateforme.

5. Data minimization

Construire un inventaire des champs personnels par microservice avec finalite, source, base legale a renseigner par compliance, retention, acces et destinations.

field: shipping_address
owner: User Profile / Order snapshot where required
purpose: delivery

```
classification: confidential
retention: policy reference
access: customer + authorized support
exportable: yes
erasable: conditional
audit: yes
```

Ne pas collecter par défaut prenom, nom ou adresse de facturation lorsqu'ils ne sont pas requis par le parcours ou une obligation applicable.

6. Privacy lifecycle

```
COLLECT
-> MINIMIZE
-> USE
-> RETAIN
-> EXPORT / RECTIFY
-> DELETE / ANONYMIZE
-> PROVE
```

Implementer les workflows techniques de droits d'accès/export, rectification et suppression/anonymisation lorsque applicables, avec vérification d'identité et audit.

7. Right-to-erasure / anonymisation

La suppression doit respecter les obligations de conservation incompatibles avec un effacement immédiat. Séparer les données supprimables des snapshots comptables/fiscaux ou antifraude qui peuvent nécessiter une conservation.

```
Erasure request
-> identity verification
-> policy evaluation
-> discover subject data
-> delete/anonymize eligible records
-> preserve legally-required records
-> invalidate caches/search projections
-> emit completion evidence
```

Les projections OpenSearch/ClickHouse et caches doivent être mises à jour/reconstruites après suppression ou anonymisation.

8. Retention-as-Code

Versionner les politiques de rétention par classe/dataset/service. Automatiser purge, anonymisation ou archivage selon policy.

```
resource: notification_delivery_log
retention: 90d
action: delete
owner: notification

resource: invoice
retention: legal-policy-reference
action: retain
owner: billing
```

Les durées exactes dépendantes de la juridiction doivent rester configurables et approuvées, pas codées en dur arbitrairement.

9. IAM / Zero Trust

Keycloak reste l'autorité IAM. OIDC/OAuth2, access tokens courts, refresh rotation/revocation, MFA/Passkeys et validation iss/aud/exp.

Kong valide l'identité en entrée ; Istio Ambient/SPIFFE fournit l'identité workload ; OPA applique les décisions de la Platform API ; les microservices revalident les permissions métier.

10. RBAC + permissions fines

role -> permission aggregation

```
catalog_manager:  
product:read  
product:write  
catalog:write
```

```
finance_manager:  
payment:read  
order:refund
```

```
support_agent:  
order:read  
customer:support
```

Tester privilege escalation, horizontal access et vertical access. Le frontend peut masquer une action, mais ne constitue jamais le controle d'autorisation.

11. Tier 0 / privileged access

Definir Tier 0 : OpenBao, Keycloak, PKI/HSM, Git governance critique, Kubernetes control plane et autres composants de confiance.

Imposer double approbation pour changements sensibles, credentials minimaux, sessions privilegiees tracees et break-glass court, justifie et audite.

12. Secrets management

```
Application  
-> workload identity  
-> OpenBao  
-> dynamic credential / short TTL  
-> database/provider
```

```
NO:  
Git secret  
long-lived app secret  
shared human credential
```

External Secrets Operator uniquement lorsqu'un composant exige un Kubernetes Secret. Rotation et revocation doivent etre testees.

13. PKI et certificats

SPIRE/Istio pour workload identity, certificats publics via la strategie edge/ACME. Surveiller expiration et renouvellement.

```
warning < 30 days  
critical < 7 days  
renewal failure -> critical incident
```

Inclure CA racines/intermediaires dans la surveillance et les runbooks.

14. Kubernetes encryption-at-rest + KMS

Activer encryption-at-rest Kubernetes avec KMS relie a OpenBao/HSM selon l'implementation retenue. Versionner la configuration et documenter rotation/re-encryption.

```
Kubernetes API  
-> encryption provider / KMS  
-> OpenBao/HSM-backed key  
-> encrypted etcd data
```

```
rotation:  
new key -> primary  
-> rewrite/re-encrypt resources
```

```
-> verify
-> retire old key only after evidence
```

Tester restauration etcd/cluster et acces aux donnees apres rotation. Une cle ne doit pas etre detruite avant validation de la re-encryption et des backups.

15. Chiffrement stockage

Appliquer LUKS/disk encryption, chiffrement Ceph si necessaire et SSE pour le stockage objet. Les clees sont geres hors des donnees, via OpenBao/HSM selon le cas.

Verifier egalement les backups : un backup non chiffre peut annuler la protection du stockage primaire.

16. Network security

```
Internet ingress
-> edge/WAF
-> Kong
-> Istio Gateway
-> service

Pod egress
-> Cilium policy
-> Istio Egress Gateway
-> Squid
-> allowlist
-> Internet
```

Cilium default-deny. Aucun acces Internet direct depuis les workloads applicatifs. Les exceptions sont documentees et testees.

17. WAF / API security

Coraza protege l'edge applicatif, Kong applique auth, rate limiting et gouvernance API. Tester payloads invalides, tailles, content-types, rate limits et erreurs.

Ne pas utiliser le WAF comme substitut a la validation applicative.

18. Webhook security standard

```
External webhook
-> dedicated Kong endpoint
-> signature/auth validation
-> timestamp / anti-replay
-> schema validation
-> rate limit
-> idempotence
-> audit
-> internal processing
```

La confirmation frontend ne fait jamais foi pour paiement, expedition ou retour. Reconciliation backend avec une source de confiance quand necessaire.

19. Payment / PCI scope reduction

Utiliser tokenisation/Hosted Fields ou equivalent PSP. Payment ne conserve que references et metadonnees necessaires : payment_id, psp_reference, type, status, amount, currency, idempotency_key, timestamps.

PAN complet et CVV ne doivent jamais transiter vers les logs, Kafka, traces, bases applicatives ou outils analytics.

20. Logging et privacy

Definir une politique de redaction centralisee pour logs/traces/events. Interdire secrets, tokens, PAN/CVV et PII non necessaire.

```
ALLOW:
order_id
payment_id
correlation_id
status

MASK/HASH where justified:
email / phone / identifiers

DENY:
password
access token
refresh token
CVV
full PAN
provider secret
```

21. Audit trail

Les actions sensibles produisent un audit immuable/logiquement append-only : actor, action, resource, decision, timestamp, request_id, correlation_id, change_id et resultat.

Splunk recoit les evenements de securite cibles : Falco, Coraza, OpenBao audit, Keycloak anomalies, Squid denied egress et correlations.

22. Runtime security

Falco surveille les comportements runtime suspects. Les alertes doivent etre qualifiees et reliees a des runbooks ; eviter les regles bruyantes sans action possible.

Pod Security restricted, seccomp RuntimeDefault, non-root, filesystem read-only, no privilege escalation, drop ALL capabilities.

23. Policy-as-Code

Kyverno bloque les manifests Kubernetes non conformes. OPA gere l'autorisation de la Platform API. Les policies sont versionnees, testees et soumises a review.

```
PR
-> policy unit tests
-> manifest tests
-> approval
-> merge
-> FluxCD
-> admission enforcement
```

24. Software supply chain

```
Source
-> protected branch
-> CODEOWNERS
-> signed commits/tags where policy requires
-> Tekton
-> tests
-> Semgrep/gosec
-> dependency/image scan
-> SBOM Syft
-> OCI build
-> Cosign signature
-> Harbor
-> digest-pinned deployment
-> FluxCD
```

Interdire en production les images non approuvees/non signees selon policy. Utiliser Robot Accounts Harbor a privileges minimaux.

25. Dependency governance

Inventorier les dependances directes/transitives, licences et vulnerabilites. Definir politique de severite, SLA de correction et processus d'exception temporaire.

Ne pas faire de mise a jour automatique aveugle d'une dependance critique sans tests.

26. Git governance

Branches protegees, CODEOWNERS, signatures, double approbation Tier 0, credentials CI minimaux, audit, sauvegarde Git immuable et restauration testee.

Les protections Git font partie du modele de securite de production, car Git/FluxCD est une source de controle.

27. Backup security

Replication != backup. Proteger CloudNativePG WAL/PITR, OpenBao snapshots, Velero, stockage objet et Git.

Backups chiffres, acces restreint, immutabilite lorsque possible, separation des credentials et tests de restauration.

28. Multi-site security

Les deux sites restent autonomes. Le failover d'ecriture exige health checks fiables, quorum/fencing et prevention stricte du split-brain.

Le GSLB/DNS ne doit jamais etre le mecanisme qui decide seul du droit d'ecrire.

29. Security testing

```
SAST -> Semgrep + gosec
Secrets -> Gitleaks
SCA/OCI -> Trivy
DAST -> OWASP ZAP
Contracts -> negative/security cases
Fuzz -> Go fuzzing
IAM -> authz escalation tests
Kubernetes -> Kyverno/policy tests
Chaos -> security-relevant failure modes
```

Reutiliser la strategie du Prompt IA 14 et produire des quality gates bloquants.

30. Privacy tests

- Un export utilisateur ne retourne que les donnees autorisees.
- Une suppression/anonymisation propage la correction aux projections.
- Les logs ne contiennent pas de secrets/PII interdite.
- Les datasets Data respectent classification et masking.
- Les permissions Support/Admin limitent les donnees visibles.
- Les retentions declenchent les purges attendues.

31. Incident response

```
Detect
-> classify
-> contain
-> preserve evidence
-> eradicate
-> recover
-> verify
-> postmortem
-> corrective PR
```

Definir runbooks pour credential leak, compromised workload, suspicious admin action, data exposure, supply-chain compromise et provider breach.

Les obligations de notification reglementaire doivent etre traitees par la procedure compliance/juridique applicable, avec les preuves techniques necessaires.

32. Vulnerability management

Construire un workflow : detect -> triage -> owner -> severity -> remediation SLA -> retest -> closure. Lier findings aux images/digests et releases.

Une exception doit avoir justification, compensating controls, approbateur et date d'expiration.

33. Evidence-as-Code

Chaque controle critique doit produire une preuve exploitable : resultats CI, policy tests, scans, signatures, SBOM, logs d'audit, restore tests et access reviews.

```
release_id
commit_sha
image_digest
sbom_digest
signature_status
security_scan_result
policy_result
approvals
deployment_result
```

34. Access reviews

Automatiser des revues periodiques des roles privileges, comptes de service, Robot Accounts, credentials et exceptions. Supprimer les acces orphelins.

Les comptes partages humains sont interdits sauf contrainte documentee exceptionnelle.

35. Environnements non-production

Ne pas reduire la securite au point de rendre les tests non representatifs. Utiliser des donnees synthetiques/anonymisees et des credentials separees.

Aucun secret de production dans dev/test/CI.

36. Security observability

```
Prometheus/Alertmanager:
availability / operational security symptoms
```

```
Splunk:
Falco
Coraza
OpenBao audit
Keycloak anomalies
Squid denied egress
privileged actions
security correlations
```

Construire dashboards et alertes avec owner/runbook. Une alerte sans action definie doit etre revue.

37. Documentation obligatoire

Produire threat models, data inventory, retention policies, RBAC matrix, privileged access model, incident runbooks, key rotation runbook, webhook standard, supply-chain policy et backup security runbook.

38. Ordre d'implementation

1. Security baseline + threat models
2. Data classification/inventory
3. IAM/RBAC/Tier-0 review
4. OpenBao/secrets/rotation

5. PKI + certificate monitoring
6. Kubernetes KMS/encryption-at-rest
7. Network/egress/WAF/API policies
8. Webhook + payment controls
9. Logging/redaction/audit
10. Runtime + Policy-as-Code
11. Supply-chain + Git governance
12. Privacy workflows + retention
13. Backup/multi-site security
14. Security/privacy tests
15. Incident/vulnerability management
16. Evidence dashboards + access reviews

39. Definition of Done

- Les données sont inventoriées, classifiées et associées à une finalité/retention.
- Les workflows privacy techniques sont testables et auditables.
- Keycloak/RBAC/permissions et accès privilégiés sont testés.
- Les secrets runtime sont distribués par OpenBao avec rotation/revocation.
- Kubernetes encryption-at-rest/KMS et rotation sont vérifiés.
- Le réseau est default-deny et l'égress passe par le chemin contrôlé.
- Les webhooks critiques appliquent signature, anti-replay, schéma et idempotence.
- Aucune donnée carte sensible interdite n'est stockée ou journalisée.
- Les logs/traces appliquent redaction et minimisation.
- Kyverno/OPA et supply-chain gates sont actifs en CI/production.
- SBOM, signatures et scans sont rattachés aux releases.
- Les backups sécurisés sont restaurables.
- Les incidents et vulnérabilités ont des workflows et runbooks.
- Les contrôles critiques produisent des preuves auditables.

Definition finale : la sécurité n'est pas un PDF de politiques. Le système doit empêcher, détecter, tracer et tester les comportements interdits, tout en produisant les preuves nécessaires à l'audit et à la validation compliance.